In some circumstances, requiring customers to be notified within 30 days may hinder law enforcement investigation of an incident by potentially making an attacker aware of the attack's detection.[803] It could also make other threat actors aware of vulnerabilities in a covered institution's systems, which they could then try to exploit. The final amendments allow a covered institution to delay notification of customers if the Attorney General determines that the notice required poses a substantial risk to national security or public safety and notifies the Commission of such determination in writing.[804] The main benefit of this delay is to decrease the likelihood of the potential situations described above where law enforcement is hindered. The delay might, in some cases, lead to a better protection of national security and public safety. Another benefit of the delay is that it might give covered institutions more time to assess the scope of the incident and gather the information to be included in the notice to customers in particularly complex cases. However, the delay provisions might also, in some cases, result in customers being notified later, which would decrease the benefits of such notification, as described above.[805] Where investigations do not rise to the level of meeting the prescribed conditions for delayed notification, customer notification could alert attackers that their intrusion has been detected and could potentially impact law enforcement's investigation.

Because we do not have data on the frequency with which an investigation will rise to the level of meeting the final amendments' conditions for delayed notification, and because we do

---

respondents would recommend to firms after a data breach, providing evidence that extending the timeframe is likely to therefore reduce the benefits of the notification requirement. *See* Lillian Ablon et al., *Consumer Attitudes Toward Data Breach Notifications and Loss of Personal Information*, RAND Corporation (2016), *available at* https://www.rand.org/pubs/research_reports/RR1187.html. Customers who receive notices faster are better able to take appropriate mitigating actions.

803 The attacker could then work to remove evidence on the covered institution's systems, thereby making the identity of the attacker harder to uncover by law enforcement.

804 *See* final rule 248.30(a)(4)(iii).

805 *See supra* text following footnote 783.

not have data on the scope of the effect on national security or public safety of breaches being revealed to the attackers, nor did commenters identify such data, we are unable to precisely estimate the costs and benefits of this provision. However, we expect that such events will be relatively rare.[806]

(3) Broader Scope of Information Triggering Notification

In the final amendments, "sensitive customer information" is defined more broadly than in most state laws, yielding a customer notification trigger that is broader in scope than the various state law notification triggers included under the baseline.[807] The broader scope of information triggering the notice requirements will cover more data breaches impacting customers than the notice requirements under the baseline. This broader scope might benefit customers who will be made aware of more cases where their information has been compromised. At the same time, the broader scope might lead to false alarms—cases where the "sensitive customer information" divulged does not ultimately harm the customer. Such false alarms might be problematic if they reduce customers' responsiveness to data breach notices. In addition, the scope will also likely imply additional costs for covered institutions, which may

---

806 *See* SIFMA comment letter 2 ("The Commission should be aware that under present practice and experience, the number of cases where delay is requested or mandated by other government entities, or court orders, is quite limited—so the SEC need not assume or fear that notification delays would become routine or be otherwise abused."). In addition, the state of California requires that, if a notice sent to individuals affected by a breach was delayed at the request of law enforcement agency, the notice mention such delay. *See* Cal. Civil Code § 1798.82. Of the 456 notices reported in 2022, only 4 indicated that they were delayed at the request of law enforcement. *See supra* footnote 777 for a description of these data. Because the final amendments' conditions for a notification delay are stricter than those under California law, we expect that the frequency at which covered institutions will delay notifications for national security and public safety reasons will be even lower.

807 *See* final rule 248.30(d)(9) and *supra* section IV.C.2.a(1).

need to adapt their processes for safeguarding information to encompass a broader range of customer information and may need to issue additional notices.[808]

In the final amendments, "sensitive customer information" is defined as "any component of customer information alone or in conjunction with any other information, the compromise of which could create a reasonably likely risk of substantial harm or inconvenience to an individual identified with the information."[809] The definition's basis in "any component of customer information" creates a broader scope than under state notification laws. In addition to identification numbers, PINs, and passwords, many other pieces of nonpublic information have the potential to satisfy this standard. For example, many financial institutions have processes for establishing identity that require the user to provide a number of pieces of information that—on their own—are not especially sensitive (e.g., mother's maiden name, name of a first pet, make and model of first car), but which—together—could allow access to a customer's account. The compromise of some subset of such information will thus potentially require a covered institution to notify customers under the final amendments.

The definitions of information triggering notice requirements under state laws are generally much more circumscribed and can be said to fall into one of two types: basic and enhanced. Basic definitions are used by 14 states, which account for 21 percent of the U.S. population.[810] In these states, only the compromise of a customer's name together with one or more enumerated pieces of information triggers the notice requirement. Typically, the enumerated information is limited to Social Security number, a driver's license number, or a financial account number combined with an access code. For the estimated 15 million potential

---

808 Estimates of certain costs related to notice issuance are discussed in section V.

809 Final rule 248.30(d)(9).

810 *See supra* section IV.C.2.a(1).

customers residing in these states,[811] a covered institution's compromise of the customer's account login and password would not necessarily result in a notice, nor would a compromise of his credit card number and PIN.[812] Such compromises could nonetheless lead to substantial harm or inconvenience. Thus, the final amendments will significantly enhance the notification requirements applicable to these customers.

States adopting enhanced definitions for information triggering notice requirements extend the basic definition to include username/password and username/security question combinations.[813] These definitions may also include additional enumerated items whose compromise (when linked with the customer's name) can trigger the notice requirement (e.g., biometric data, tax identification number, and passport number).[814] For the estimated 55 million potential customers residing in the states with enhanced definitions,[815] the benefits from the final amendments will be somewhat more limited. However, even for these customers, the amendments will tighten the effective notification requirement. There are many pieces of information not covered by the enhanced definitions whose compromise might potentially lead to substantial harm or inconvenience. For example, under California law, the compromise of information such as a customer's email address in combination with a security question and answer would only trigger the notice requirement if that information would—in itself—permit access to an online account. Under many such state laws, the compromise of information such as

---

811 *See supra* footnote 767.

812 *See supra* text accompanying footnote 532.

813 *See supra* section IV.C.2.a(1).

814 *See id*.

815 *See supra* footnote 767.

a customer's name, combined with his or her transaction history, account balance, or other information not specifically enumerated would not necessarily trigger the notice requirement.

The broader scope of information triggering a notice requirement under the final amendments will benefit customers. As discussed above, many pieces of information not covered under state data breach laws could, when compromised, cause substantial harm or inconvenience. Under the amendments, data breaches involving such information might require customer notification in cases where state law does not, and thus potentially increase customers' ability to take actions to mitigate the effects of such breaches. At the same time, there is some risk that the broader minimum standard will lead to notifications resulting from data compromises that—while troubling—are ultimately less likely to cause substantial harm or inconvenience.[816] A large number of such unnecessary notices might undermine the effectiveness of the notice regime.[817]

The broader minimum standard for notification is likely to result in higher costs for covered institutions. There will be increased administrative costs related to preparing and distributing notices for covered institutions who will send out additional notices as a result of the scope of information triggering a notice requirement under the final amendments. As discussed below, we estimate that certain costs associated with the preparation and distribution of notices will be, on average, $5,178 per year per covered institution.[818]

---

816 This may be the case even though the amendments include an exception from notification when the covered institution determines, after investigation, that the sensitive customer information has not been, and is not reasonably likely to be, used in a manner that would result in substantial harm or inconvenience. For example, the covered institution could decide to forgo investigations and always notify, or it could investigate but not reach a conclusion that satisfied the terms of the exception.

817 *See infra* section IV.D.1.b(4) for a discussion of the effects of notification specifically.

818 This estimate is an annual average for the first three years. The corresponding ongoing annual costs beyond the first three years are estimated to be on average $3,862 per year per covered institution. *See infra* section V.

In addition, it is possible that covered institutions have developed processes and systems designed to provide enhanced information safeguards for the specific types of information enumerated in the various state laws. For example, it is likely that IT systems deployed by financial institutions only retain information such as passwords or answers to security questions in hashed form, reducing the potential for such information to be compromised. Similarly, it is likely that such systems limit access to information such as Social Security numbers to a limited set of employees. It may be costly for covered institutions to upgrade these systems to expand the scope of enhanced information safeguards.[819] In some cases, it may be impractical to expand the scope of such systems. For example, while it may be feasible for covered institutions to strictly limit access to Social Security numbers, passwords, or answers to secret questions, it may not be feasible to apply such limits to account numbers, transaction histories, account balances, related accounts, or other potentially sensitive customer information. In these cases, the adopted minimum standard might not have a significant prophylactic effect and might lead to an increase in reputation and litigation costs for covered institutions resulting from more frequent breach notifications.

Furthermore, because the definition of sensitive customer information is based on a determination that the compromise of this information could create a "reasonably likely risk of substantial harm or inconvenience to an individual identified with the information,"[820] it could increase costs related to incident evaluation, outside legal services, and litigation risk. While we lack data, and no commenter suggested such data, that would allow us to quantify all of these

---

819 We lack data, and no commenter suggested such data, that would allow us to quantify the indirect costs resulting from any potential upgrade to customer information safeguards that covered institutions could choose to implement as a result of the final amendments in order to avoid potential reputational costs associated with customer notification following a breach.

820 Final rule 248.30(d)(9). *See supra* section II.A.3.c; *infra* section IV.D.1.b(4).

costs, we discuss below certain costs associated with developing and implementing policies and procedures to comply with the final amendments, including costs for internal and external counsel.[821] This subjectivity could reduce consistency in the propensity of covered institutions to provide notice to customers, reducing the utility of such notices in customers' inferences about covered institutions' safeguarding efforts.

Some commenters opposed the proposed amendments' definition of sensitive customer information, suggesting either a better alignment with existing regulation,[822] or that the final amendments specify a list of customer information included in the definition.[823] Covered institutions will have to devote some resources determining what specific pieces of information are included in the scope of the final notification requirements. However, different types of covered institutions may keep different types of customer information, the information collected by covered institutions might change in the future, and the type of information that could create a reasonably likely risk of substantial harm or inconvenience to an individual might also change in the future. Thus, having a wide and general range of sensitive customer information trigger the amendments' notice requirement will provide benefits to the affected customers, who may not receive a notice under the baseline. In addition, as discussed above, existing regulations adopt widely different definitions of customer information triggering a breach notification, making alignment difficult.[824]

---

821 *See infra* section V.

822 *See* Computershare Comment Letter; ICI Comment Letter 1; SIFMA Comment Letter 2.

823 *See* CAI Comment Letter; SIFMA Comment Letter 2.

824 *See supra* section IV.C.2.a(1).

(4) Notification Trigger

The final amendments include a requirement for a covered institution to provide notice to individuals whose sensitive customer information was, or is reasonably likely to have been, accessed or used without authorization, unless, after a reasonable investigation of the facts and circumstances of the incident of unauthorized access to or use of sensitive customer information, the covered institution has determined that sensitive customer information has not been, and is not reasonably likely to be, used in a manner that would result in substantial harm or inconvenience.[825] As discussed above, the final amendments reflect a presumption of notification: a covered institution must provide a notice unless it determines notification is not required following a reasonable investigation.[826] Moreover, if the covered institution is unable to determine which customers are affected by a data breach, a notice to all potentially affected customers is required.[827] The resulting presumptions of notification are important because although it is usually possible to determine what information could have been compromised in a data breach, it is often not possible to determine what information was compromised or to estimate the potential for such information to be used in a way that is likely to cause harm.[828] Because of this, it may not be feasible to establish the likelihood of sensitive customer information being used in a manner that would result in substantial harm or inconvenience or of

---

825 *See* final rule 248.30(a)(4)(i).

826 *See supra* section II.A.3. A covered institution's determination that there is no risk of harm or inconvenience may also take into consideration whether the compromised data was encrypted. *See supra* section II.A.3.b. We expect that this could mitigate the risk of unnecessary notification. We considered a safe harbor from the definition of sensitive customer information for encrypted information. *See infra* section IV.F.3.

827 *See* final rule 248.30(a)(4)(ii); *see also supra* section II.A.3.a.

828 Many covered institutions, especially smaller investment advisers and broker-dealers, are unlikely to have elaborate software for logging and auditing data access. For such entities, it may be impossible to determine what specific information was exfiltrated during a data breach.

sensitive customer information pertaining to a specific individual being accessed or used without authorization. Consequently, in the absence of the presumptions of notification, it may be possible for covered institutions to avoid notifying customers in cases where it is unclear what information was compromised or whether sensitive customer information was or is reasonably likely to be used in a manner that would result in substantial harm or inconvenience.

Currently, 20 states' notification laws do not include a presumption of notification.[829] We do not have data with which to estimate reliably the effect of these presumptions on the propensity of covered institutions to issue customer notifications, and no commenter suggested such data. However, we expect that for the estimated 20 million potential customers residing in the 20 states without a presumption of notification,[830] some notifications that will be required under the final amendments would not occur under the baseline. Thus, we anticipate that the final amendments will improve these customers' ability to take actions to mitigate the effects of data breaches. In addition, the final amendments' presumptions for notification rest on a concept of "substantial harm or inconvenience" that is likely to be wider than the equivalent concept of "harm" used in some state laws.[831] Hence, we also expect that the presumptions of notification will have potential benefits even for the customers residing in some of the states with a presumption of notification.

The increased sensitivity of the notification trigger resulting from the presumptions of notification will result in additional costs for covered institutions, who will bear higher

---

829 *See supra* section IV.C.2.a(1).

830 *See id.*; *see also supra* footnote 767.

831 *See supra* section II.A.3.c for a discussion of the concept of "substantial harm or inconvenience." Some states use a narrower definition of harm, for example including only fraud or financial harm. *See supra* section IV.C.2.a(1); *see also* Fla. Stat. § 501.171(4)(c) and Iowa Code § 715C.2(6) for examples of states with a presumption for notification but a narrower concept of harm.

reputational costs (including indirect costs of customer information protection improvements that may be undertaken to avoid such reputational costs) as well as some additional direct compliance costs (e.g., mailing notices, responding to customer questions, etc.) due to more breaches requiring customer notification. While we are unable to quantify all of these additional costs,[832] we estimate that certain costs associated with the preparation and distribution of notices will be, on average, $5,178 per year per covered institution.[833]

Some commenters disagreed with the proposed requirement that if a covered institution were unable to determine which customers were affected by a data breach, it would have had to notify all individuals whose sensitive customer information resided in the customer information system that was, or was reasonably likely to have been, accessed or used without authorization.[834] One commenter stated that this would result in significant over-notification of individuals, and that this would unnecessarily disturb and frighten individuals who likely were not affected.[835] The commenter also stated that the proposed requirements would significantly increase costs and litigation risk for covered institutions and possibly their service providers and other financial institutions whose information resides on the system.[836] Another commenter stated that this proposed provision would create reputational risks for transfer agents and that it believed resources would be better spent investigating the incident and determining the impacted

---

832 As stated above, we do not have data with which to estimate reliably the effect of these presumptions on the propensity of covered institutions to issue customer notifications, and no commenter suggested such data. In addition, as stated above, we lack data, and no commenter suggested such data, that would allow us to quantify the indirect economic costs, such as reputational cost of any potential increase in the frequency of customer notification. *See supra* section IV.D.1.a.

833 This estimate is an annual average for the first three years. The corresponding ongoing annual costs beyond the first three years are estimated to be on average $3,862 per year per covered institution. *See infra* section V.

834 *See, e.g.*, CAI Comment Letter; IAA Comment Letter 1.

835 *See* CAI Comment Letter.

836 *See* CAI Comment Letter.